

Florida Critical Infrastructure Cybersecurity Intelligence

Situational Awareness Bulletin #08-2026

Cyber Threat Outlook

Florida's critical infrastructure faces a compounding threat environment over the next 6 to 18 months, driven by geopolitical escalation, industrialized ransomware, and an accelerating AI-enabled exploitation cycle. Iranian-affiliated actors, including Cyber Av3ngers and Ababil of Minab, are actively exploiting internet-exposed programmable logic controllers (PLCs, the computerized devices that manage physical industrial processes) across transit, water, and energy sectors, while Chinese state-sponsored groups have industrialized botnet infrastructure and compromised perimeter edge devices to pre-position within U.S. networks. Nation-state and hacktivist attacks on critical infrastructure doubled in 2025, and living-off-the-land (LOTL) tactics, which repurpose legitimate system tools to evade detection, are rendering software-based defenses increasingly insufficient. Ransomware losses rose 159% in 2025, and ransomware-as-a-service (RaaS) alliances such as Vect and TeamPCP are automating initial access and data exfiltration to target industrial control environments at scale. The unauthorized access to a frontier AI model capable of autonomous multi-step cyberattacks signals an emerging inflection point: if that capability is weaponized, the window for patching critical vulnerabilities may compress from days to hours. Supply-chain compromises spanning developer package registries, third-party analytics vendors, and CI/CD (continuous integration and delivery, the automated pipelines used to build and deploy software) systems are now a primary initial access vector across all sectors, making the partner ecosystem as significant a threat surface as directly managed assets. Florida organizations should treat hardware-enforced segmentation, tested manual continuity procedures, and rigorous third-party vendor oversight as baseline posture requirements for this threat environment.

Confidence - High

Executive Summary

- **All Sectors:** Iranian-affiliated actors are actively exploiting default credentials on Rockwell Automation, Allen-Bradley, and Unitronics PLCs (programmable logic controllers) across transit and water sectors, while Chinese state-sponsored groups have industrialized botnet infrastructure targeting U.S. critical infrastructure networks. A compromised Bitwarden CLI (command-line interface) package separately demonstrates escalating supply-chain risks to cloud credentials across all sectors.
- **Commercial Facilities:** A ransomware attack at the Port of Vigo forced cargo operations onto manual paper manifests — a direct operational analog for Florida's Port Miami and

Port Everglades — while ShinyHunters breached ADT and Alert 360, exposing personal data for a combined approximately 8 million customers.

- **Communications:** Ongoing global surveillance campaigns are exploiting long-known weaknesses in SS7 and Diameter signaling protocols to track and intercept mobile users without device infection, exposing Florida telecommunications providers reliant on legacy international roaming agreements.
- **Critical Manufacturing:** The Vect RaaS (ransomware-as-a-service) operation has formalized an alliance with TeamPCP and BreachForums to automate attacks at industrialized scale, specifically targeting manufacturing and industrial control environments that rely on Rockwell Automation systems.
- **Energy:** Destructive "Lotus" wiper malware has rendered industrial workstations unbootable at regional energy providers, while NERC (North American Electric Reliability Corporation) issued a Level 2 alert on grid frequency risks from rapid AI data center load fluctuations — a direct exposure for Florida's growing high-density data center market.
- **Financial Services:** Unauthorized access to Anthropic's autonomous frontier AI model via a third-party contractor environment signals that weaponized AI could compress vulnerability patching windows from days to hours. Confirmed breaches at Citizens Financial Group, Frost Bank, and Ameriprise Financial reinforce that third-party vendor compromise is now the primary attack vector for Florida's financial sector.
- **Food and Agriculture:** Critical vulnerabilities in Yokogawa and Rockwell Automation hardware — including hardcoded credentials — could allow unauthorized actors to manipulate production parameters or trigger emergency shutdowns in Florida food processing facilities where precise temperature and chemical control is safety-critical.
- **Government Services and Facilities:** A China-linked "FIRESTARTER" backdoor persisting through firmware updates was identified on federal Cisco Firepower devices, prompting CISA Emergency Directive 25-03. Separately, a Florida resident pleaded guilty to acting as a criminal intermediary while posing as a ransomware negotiator, underscoring insider threat risk within third-party cybersecurity contractors.
- **Healthcare and Public Health:** Ransomware attacks on hospitals in Massachusetts, Idaho, and the United Kingdom caused ambulance diversions, cancelled chemotherapy, and nearly two weeks of disrupted imaging — outcomes directly replicable in Florida's regional trauma networks. A concurrent attack on EHR (Electronic Health Record) vendor ChipSoft simultaneously disconnected eleven hospitals, demonstrating cascading third-party risk across entire health networks.
- **Information Technology:** Active exploitation of vulnerabilities in Microsoft SharePoint, Apache ActiveMQ — foundational to many Florida state agency data-sharing architectures — and the Intel Driver and Support Assistant enables remote code execution (RCE, executing malicious commands from a distance) and administrative hijacking. CISA mandates ActiveMQ patching by April 30, 2026.
- **Transportation Systems:** The TSA (Transportation Security Administration) has opened a public comment period through June 15, 2026, to evaluate cybersecurity reporting and assessment burdens for pipeline and rail operators, providing Florida transportation stakeholders a direct opportunity to shape federal requirements.
- **Water and Wastewater Systems:** A ransomware attack on Romania's national water authority confirmed that network segmentation kept dam and flood-monitoring controls

operational despite administrative system loss — a critical model for Florida utilities managing flood response. Global scans separately identify widespread exposure of FTP (File Transfer Protocol) servers supporting water management systems, frequently configured with default credentials

All Sectors

Iran-Linked Hackers Target Public Transit and Industrial Systems via PLC Exploitation

Sources: [Iranian-Affiliated Cyber Actors Exploit PLCs Across U.S. Critical Infrastructure](#) | [Ababil of Minab Claims Responsibility for Cyberattack on Los Angeles Metro](#) | [Cyber Av3ngers Intensify Operations Against U.S. Water and Wastewater Systems](#) United States

federal agencies, including the Cybersecurity and Infrastructure Security Agency (CISA), the Federal Bureau of Investigation (FBI), the National Security Agency (NSA), the Environmental Protection Agency (EPA), the Department of Energy (DOE), and U.S. Cyber Command, issued a joint alert regarding an escalating campaign by Iranian-affiliated cyber threat actors, such as "Cyber Av3ngers" and "Ababil of Minab," targeting internet-exposed operational technology (OT) across the country. These cyber threat actors are successfully exploiting programmable logic controllers (PLCs), specifically targeting Rockwell Automation and Allen-Bradley programmable logic controllers, including CompactLogix and Micro850 models, by leveraging default credentials and insecure remote access pathways. Notably, actors used Rockwell Automation's own Studio 5000 Logix Designer software on leased offshore infrastructure to connect to victim PLCs, making the intrusion activity harder to distinguish from authorized engineering operations than a simple default-credential attack. While those devices were specifically targeted, the advisory notes that the port targeting patterns suggest other OT vendors may also be at risk. Ababil of Minab, a pro-Iranian hacktivist group with a limited prior track record, claimed responsibility for a March 2026 breach of the Los Angeles County Metropolitan Transportation Authority (LACMTA), publishing screenshots purportedly showing access to rail yard management displays; LACMTA confirmed unauthorized access to administrative systems but has not independently verified the group's claims of operational technology access. Additionally, water utilities have reported disruptive activities such as configuration wiping and the defacement of human-machine interface (HMI) screens. This escalation is highly relevant to Florida, where municipal utilities and transit networks rely on these specific controller types, necessitating immediate action to remove OT assets from the public-facing internet and implement robust authentication protocols.

[Nation-State And Hacktivist Attacks On Critical Infrastructure Doubled In 2025](#) Published in late March 2026, the Waterfall/ICS STRIVE 2026 OT Cyber Threat Report indicated a strategic shift in the industrial threat landscape. While total recorded physical breaches decreased to 57 incidents in 2025, largely due to a temporary dip in ransomware activity, attacks by nation-

state actors and hacktivists increased 100%. These incidents frequently involve living-off-the-land (LOTL) tactics to evade software-based defenses, resulting in production shutdowns in the automotive sector and disruptions to maritime navigation through Global Positioning System (GPS) spoofing. This data is relevant to Florida as the state's CI sectors, including oil and gas, water, and power, are identified as primary targets for these sophisticated adversaries, necessitating a move toward hardware-enforced protections and manual fallback procedures to ensure operational continuity.

Joint Advisory as Cyberattacks Target US Infrastructure As of April 14, 2026, United States federal agencies issued a joint advisory warning of escalated cyberattacks targeting Critical Infrastructure (CI) due to ongoing Middle East conflicts. Cyber threat actors are actively exploiting internet-exposed OT devices, specifically those used in the energy, water, and local government sectors, to interfere with physical systems. The World Economic Forum (WEF) Global Cybersecurity Outlook 2026 report indicates that 64% of organizations now prioritize geopolitical tensions in their risk mitigation strategies. This development is relevant to Florida as the state's high concentration of municipal water and power utilities often utilizes similar internet-connected industrial hardware, making them prime targets for state-sponsored disruption or retaliatory strikes.

FBI: Ransomware Still A Top Threat To Critical Infrastructure As of April 14, 2026, the FBI Internet Crime Complaint Center (IC3) released its 2025 report, documenting a 159% increase in reported ransomware losses. For the first time, the IC3 report tracked AI-enabled cybercrime as a formal category, with 22,364 complaints and nearly \$893 million in losses — underscoring that AI is already being weaponized in operational fraud schemes, not merely a future concern. Of the 16 CI sectors, the Healthcare and Public Health sector reported the highest volume with 460 incidents. Ransomware variants including Akira, Qilin, and INC Ransom — the top reported groups by complaint volume — increasingly utilize double-extortion tactics. This report is relevant to Florida as the Florida Legislature recently passed a bill (House Bill 1085 and Senate Bill 576) that is awaiting gubernatorial action to formalize state-funded cybersecurity aid for local governments, addressing the persistent threat these sophisticated ransomware groups pose to Florida's municipal utilities and public services.

Escalation Of Cyber Risk Related To Iran As of April 17, 2026, Iranian-linked cyber threat actors, including the cluster CL-STA-1128 (also identified as Cyber Av3ngers), have launched retaliatory cyber operations following significant regional strikes. Unit 42 identified approximately 60 active hacktivist groups in this campaign environment, many coordinating under an 'Electronic Operations Room' framework established in late February 2026, meaning the threat extends well beyond the two named groups and cannot be managed through actor-specific intelligence alone. The cyber threat actors used Rockwell Automation's FactoryTalk software on virtual private servers (VPS) to facilitate exploitation. Tactics include the deployment of wiper malware to delete data, sophisticated credential phishing mimicking

enterprise resources, and Distributed Denial-of-Service (DDoS) attacks. This activity is highly relevant to Florida because state CI sectors, particularly energy and manufacturing, rely heavily on Rockwell Automation systems, making them susceptible to these targeted disruptive efforts and potential operational downtime.

CISA Adds Zimbra Collaboration Suite and Seven Other Vulnerabilities to Known

Exploited Catalog On April 20, 2026, CISA added eight vulnerabilities to its Known Exploited Vulnerabilities (KEV) Catalog. Among these is a high-severity Zimbra Collaboration Suite flaw (CVE-2024-35176) being actively exploited to compromise mail servers. While Binding Operational Directive (BOD) 22-01 mandates remediation for federal agencies, CISA strongly urges all CI owners and operators to prioritize these patches. Failure to remediate these flaws could lead to unauthorized access to enterprise communications and credential exfiltration.

Bitwarden CLI npm Package Hijacked to Steal Cloud Credentials and Self-Propagate On April 22, 2026, a malicious version of the Bitwarden command-line interface (CLI) (@bitwarden/cli@2026.4.0) was published to the npm registry. Linked by overlapping malware infrastructure to threat actor TeamPCP, which claimed the related Checkmarx attack — researchers note the Bitwarden payload's thematic overlap with a prior separate campaign complicates definitive attribution. The malware targets developer workstations and continuous integration and continuous delivery (CI/CD) pipelines to harvest Amazon Web Services (AWS), Azure, and Google Cloud Platform (GCP) credentials, Secure Shell (SSH) keys, and GitHub tokens. The attack's entry point was a compromised GitHub Action in Bitwarden's CI/CD pipeline, enabled by the simultaneous Checkmarx KICS supply chain attack. Notably, the payload exhibits worm-like behavior by attempting to backdoor any other npm packages the victim has permission to publish. Security teams should immediately audit package.json files and rotate all credentials if version 2026.4.0 was installed. Organizations running Checkmarx KICS Docker images or GitHub Actions in their own pipelines should treat those environments as potentially exposed regardless of whether they installed the Bitwarden CLI.

US and Allies Warn of "Industrialized" Chinese Botnets Targeting Critical Infrastructure

A joint advisory from CISA, the FBI, and international partners warns that Chinese state-sponsored actors, including Volt Typhoon and Flax Typhoon, have "industrialized" the creation of botnets using hundreds of thousands of compromised small office/home office (SOHO) routers and Internet of Things (IoT) devices (KV Botnet). Unlike traditional botnets used for spam, these covert networks are engineered to provide a persistent, non-attributable staging ground for intrusions into U.S. CI. The advisory notes that these botnets are often maintained by Chinese information security firms and target outdated Netgear and Cisco hardware.

China Targeting Western Defense and Aerospace Sectors via Compromised Edge Devices

The Dutch General Intelligence and Security Service (AIVD) warns of an intensified Chinese state-sponsored campaign targeting the defense, aerospace, and semiconductor industries. Cyber threat actors are primarily exploiting vulnerabilities in internet-facing "edge" devices, such as

firewalls and virtual private network (VPN) gateways, to gain initial access. Once inside, they deploy modular malware to exfiltrate intellectual property related to defense technologies. This trend is highly relevant to Florida's extensive defense industrial base, highlighting the need for immediate patching of perimeter hardware and zero-trust architecture.

Pack2TheRoot Flaw Provides Unprivileged Local Users Root Access on Major Linux Distributions

Security researchers publicly disclosed "Pack2TheRoot" (CVE-2026-41651), a high-severity local privilege escalation vulnerability affecting multiple Linux distributions including Ubuntu, Debian, and Rocky Linux. The flaw lies in the PackageKit daemon, which can be exploited by an unprivileged local user to obtain full root access in seconds. Because PackageKit is an optional dependency of the Cockpit project, many servers, including those running Red Hat Enterprise Linux (RHEL), may be vulnerable. Administrators should update PackageKit to version 1.3.5 or apply distribution-specific backports immediately to prevent total system compromise from local footholds.

Hacker Who Allegedly Carried Out Cyberattacks for China is Extradited to U.S. A Chinese national, Xu Zewei, has been extradited from Italy to the United States to face charges for state-sponsored hacking. Xu is allegedly a member of the "Silk Typhoon" group, also known as Hafnium, and is accused of targeting U.S. universities, virologists, and government agencies between 2020 and 2021. The attacks notably weaponized zero-day vulnerabilities in Microsoft Exchange Server to deploy web shells for remote administration. This extradition underscores the persistent legal and cybersecurity pressure on state-sponsored actors targeting American research and critical infrastructure.

Checkmarx Confirms GitHub Repository Data Posted on Dark Web Following Supply Chain Attack

Cybersecurity firm Checkmarx confirmed that data stolen from its GitHub repository during a March 2026 supply chain attack has been published on the dark web. The breach originated from a compromise of the Trivy security scanning tool, which allowed attackers to insert malicious code and steal internal credentials. This incident is part of a broader campaign that also impacted LiteLLM, a widely used Python library for building artificial intelligence (AI) tools. Florida organizations utilizing automated security scanning and continuous integration and continuous delivery (CI/CD) pipelines should immediately rotate credentials and audit for unauthorized repository access.

AiFrame Browser Attacks Continue with Fake Authenticator and Converter Extensions

The "AiFrame" browser attack campaign has expanded to include new malicious Chrome extensions that impersonate two-factor authentication (2FA) authenticators and file converters. These extensions, such as "2FA Authenticator," request excessive permissions to read and modify website content, allowing attackers to inject phishing iframes or overlay fake paywalls. This campaign has affected approximately 260,000 users to date. Florida critical infrastructure

employees should be restricted from installing unverified browser extensions on corporate workstations to prevent credential theft and session hijacking.

All Sectors Recommendations:

- Identify and remove all industrial control systems (ICS) and PLCs from the public-facing internet immediately to mitigate exploitation by Iranian-affiliated cyber threat actors.
- Change all default passwords on OT hardware and implement phishing-resistant multi-factor authentication (MFA) for all authorized remote access pathways.
- Perform immediate audits of developer environments and package.json files for malicious npm packages, rotating all cloud credentials if compromised versions like Bitwarden CLI 2026.4.0 were installed.
- Prioritize the patching of high-severity vulnerabilities listed in the CISA KEV Catalog, specifically addressing Zimbra Collaboration Suite and Apache ActiveMQ flaws.
- Update the PackageKit daemon to version 1.3.5 on all Linux-based servers to prevent unprivileged local users from obtaining full root access through the "Pack2TheRoot" vulnerability.
- Scan all compromised or suspect PLC environments for unauthorized Dropbear SSH installations and other persistence mechanisms, as confirmed intrusions in this campaign include long-term access tools beyond the initial exploitation event."

Chemical Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period.

Commercial Facilities Sector

Ransomware Attack Disrupts Digital Operations At Spain's Port of Vigo On March 24, 2026, the Port of Vigo, a critical maritime hub in Galicia, Spain, detected a financially motivated ransomware attack that locked computer servers used to coordinate cargo traffic and logistics. In response, the port authority's technology team isolated the affected systems from external networks, disrupting digital services without halting physical ship movements. Port President Carlos Botana stated that systems would remain offline until "absolute guarantees" of safety are met, necessitating the use of manual procedures and paper manifests for container processing. While no specific cyber threat actor has claimed responsibility, the attack vector has not been publicly confirmed; the port authority has stated an investigation is ongoing. This incident is relevant to Florida as a major maritime state; the shift to manual "fallback" procedures at the Port of Vigo highlights a growing operational requirement for Florida's ports (e.g., Port Miami, Port Everglades) to maintain high-fidelity analog backups and hard network segmentation to ensure cargo throughput continues even during a total loss of digital logistics platforms.

ShinyHunters Leaks 2.5 Million Records Following Alert 360 Extortion Attempt As of April 2026, the cyber threat actor ShinyHunters published 106 gigabytes (GB) of stolen Alert 360 data after a failed extortion attempt. The leak impacts 2.5 million customers, exposing personally identifiable information (PII) and technical system data. The cyber threat actor utilized sophisticated vishing and multi-factor authentication (MFA) bypass tactics to infiltrate the company's Software-as-a-Service (SaaS) environment. This is highly relevant to Florida, where Alert 360's home automation footprint is significant, because exposed configurations pose physical security risks. Florida organizations must prioritize phishing-resistant MFA and monitor cloud platforms for anomalous bulk data exfiltration to counter these identity-centric attacks.

Home Security Firm ADT Confirms Data Breach Impacting 5.5 Million Customers In April 2026, the home security firm ADT confirmed a significant data breach after being listed on an extortion site by the ShinyHunters group. The breach impacted approximately 5.5 million unique email addresses along with names, phone numbers, and physical addresses. In a small percentage of cases, dates of birth and partial Social Security numbers were also exposed. While customer security systems and payment data were not compromised, the leak of physical addresses and technical system data for a home security provider poses unique physical safety risks. Florida-based customers should remain vigilant for targeted social engineering or vishing attacks leveraging this stolen information.

Commercial Facilities Sector Recommendations:

- Maintain high-fidelity analog backups and paper-based manifest procedures to ensure the continuity of cargo throughput and logistics during a total loss of digital platforms.
- Implement hard network segmentation between administrative logistics systems and physical operational controls to prevent ransomware from halting critical maritime or facility movements.
- Prioritize the deployment of phishing-resistant MFA to counter sophisticated vishing and MFA-bypass tactics targeting SaaS environments.
- Monitor cloud-based management platforms for anomalous bulk data exfiltration and unauthorized access to customer PII or technical system configurations.
- Enhance vigilance against targeted social engineering and vishing attacks that leverage leaked personal information, such as physical addresses and partial Social Security numbers, from home security provider breaches.

Communications Sector

Global Surveillance Campaigns Exploit 3G/4G Signaling Vulnerabilities to Track Telecom Users A Citizen Lab investigation into commercial surveillance vendors (CSVs) reveals ongoing exploitation of long-known vulnerabilities in Signaling System No. 7 (SS7) for third-generation (3G) networks and Diameter for fourth-generation (4G) signaling protocols. Cyber threat actors

are using operator-level network access to conduct covert location tracking and traffic interception without infecting the target's device. Tactics involve "SIM-steering" to route data through compromised interconnects. This highlights a systemic risk to telecommunications providers who rely on legacy roaming agreements. Providers are urged to monitor for non-standard message formats in international signaling traffic.

Communications Sector Recommendations:

- Audit roaming agreements and third-party provider access to identify potential network entry points for unauthorized surveillance traffic.
- Implement the latest security features for Diameter (4G) and SS7 (3G) protocols to mitigate signaling-level exploits used for covert location tracking.
- Monitor international signaling traffic for non-standard message formats, ordered Transaction Identifiers (TIDs), and patterned session identifiers.
- Deploy signaling firewalls to detect and block malicious Short Message Service (SMS) messages containing hidden Subscriber Identity Module (SIM) card commands.
- Validate the identity of peer operators to prevent spoofing attempts designed to steer traffic through compromised interconnect paths.

Critical Manufacturing Sector

Vect RaaS Formalizes Alliance with TeamPCP to Industrialize Ransomware Scale The Vect ransomware-as-a-service (RaaS) operation has announced a formal alliance with cyber threat actors TeamPCP and BreachForums to industrialize the scale of their attacks. This industrialized model focuses on automating the initial access and data exfiltration phases specifically targeting critical manufacturing and industrial control environments. The alliance aims to provide a streamlined pipeline for affiliates to deploy ransomware at a higher volume with refined tactics, techniques, and procedures (TTPs). Manufacturers should prioritize hardening remote-access gateways and monitoring for unauthorized data staging on internal servers

Critical Manufacturing Sector Recommendations:

- Audit software supply chains for compromised developer operations (DevOps) tools and continuous integration and continuous delivery (CI/CD) components, specifically Trivy, GitHub Actions, and Checkmarx. Keeping Infrastructure as Code Secure (KICS), and immediately rotate all cloud provider credentials such as Amazon Web Services (AWS), Azure, and Google Cloud Platform (GCP) if affected versions were utilized.
- Harden industrial workstations by disabling Windows Remote Management (WinRM) where not operationally required, enforcing Server Message Block (SMB) signing, and implementing network segmentation rules to block east-west SMB and WinRM traffic.

- Implement dedicated jump hosts protected by phishing-resistant multi-factor authentication (MFA) for all administrative access to VMware ESXi and other hypervisor management planes.
- Configure security information and event management (SIEM) alerting to monitor for bcdedit command execution and modifications to SafeBoot registry keys, which are known precursors to Vect ransomware suppressing security tools.
- Enforce application allowlisting and behavior-based detection to alert on intermittent file encryption patterns, mass file renaming, or the abnormal termination of backup and security services.
- Block outbound connections to The Onion Router (TOR) entry nodes and prevent onion-based Domain Name System (DNS) resolution to disrupt Vect's command-and-control and negotiation infrastructure.

Dams Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period.

Defense Industrial Base Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period.

Emergency Services Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period.

Energy Sector

New "Lotus" Data Wiper Targeted Venezuelan Energy Utility Firms Security researchers have identified a new destructive malware variant, dubbed "Lotus," utilized in attacks against Venezuelan energy providers. The wiper is designed to overwrite physical drive sectors with zeros, delete restore points, and systematically erase all files across mounted volumes, leaving systems in an unrecoverable state. While the attack is regional, the tradecraft used to bypass industrial security controls represents a significant "transferable risk" to United States energy infrastructure. Operators should ensure that backups for Human-Machine Interfaces (HMIs) are stored offline and are immutable. Kaspersky identified the wiper as compiled in late September 2025 and pre-staged on victim systems before the destructive phase, indicating months of prior access; the threat actor's identity remains unattributed."

NERC Issues Alert on Data Center Load Disruptions Impacting Grid Stability The North American Electric Reliability Corporation (NERC) is preparing to issue a Level 3 essential actions alert, expected May 4, 2026, regarding rapid large-scale load disconnections from AI data centers — an escalation from the Level 2 advisory it issued in September 2025 on the same risk. The advisory notes that abrupt changes in data center power consumption can cause cascading failures if not properly coordinated with utility operators. NERC's incident review documented events in which approximately 1,500 MW of data center load disconnected simultaneously during a normally cleared fault, driving frequency and voltage instability that required immediate operator intervention — a scenario that grows more likely as Florida's high-density AI data center footprint expands. Energy providers in Florida, currently managing high-density data center growth, are urged to implement enhanced real-time telemetry and automated load-shedding agreements with large-scale industrial consumers.

Energy Sector Recommendations:

- Ensure that all backups for HMIs and critical industrial workstations are stored offline in an immutable format to mitigate the risk of destructive data-wiper malware.
- Implement enhanced real-time telemetry to monitor rapid, large-scale load fluctuations associated with high-density AI data center operations.
- Establish automated load-shedding agreements and coordination protocols with large-scale industrial consumers to prevent cascading grid failures.
- Verify that all internet-exposed operational technology (OT) devices, such as Rockwell Automation and Allen-Bradley programmable logic controllers (PLCs), are removed from the public-facing internet.
- Place all PLCs in "Run" mode and eliminate default passwords to prevent unauthorized remote configuration changes or system sabotage.

Financial Services Sector

Everest Ransomware Gang Targets Citizens Financial Group and Frost Bank As of April 2026, the Everest ransomware group added Citizens Financial Group and Frost Bank to its leak site, claiming to have exfiltrated over 3.6 million records. Both institutions attributed the breach to a third-party vendor rather than direct network compromise. While much of the data was reportedly "masked test data," sensitive personally identifiable information (PII) was exposed, leading to immediate federal class-action lawsuits. This incident highlights the critical nature of third-party risk and the necessity for Florida's financial and legal sectors to implement real-time monitoring of external data flows and more rigorous vendor management protocols.

Trojanized Android App Fuels New Wave of NFC Fraud As of April 2026, ESET researchers identified a new variant of the NGate malware family distributed via phishing sites impersonating Google Play and lottery platforms. Unlike previous versions that used open-

source tools, this campaign "patches" the legitimate HandyPay application with malicious code, likely developed using generative artificial intelligence (GenAI) tools, to relay Near Field Communication (NFC) card data and capture personal identification numbers (PINs) through a fake input box. Once intercepted, attackers use the data on their own NFC-enabled devices to perform unauthorized contactless transactions or withdraw cash from automated teller machines (ATMs). This development is relevant to Florida as a reminder that mobile security depends heavily on app provenance. Florida's large population of mobile payment users and retirees are prime targets for social engineering campaigns that encourage sideloading "support" or "protection" applications.

Anthropic Investigates Unauthorized Access to Mythos AI Model As of April 22, 2026, Anthropic confirmed an investigation into unauthorized access to Claude Mythos Preview, a frontier model that has demonstrated unprecedented agentic cyber capabilities, including demonstrating the ability to identify a 27-year-old vulnerability in OpenBSD and to find 271 security flaws in Mozilla Firefox in a structured evaluation. Mythos was released under Project Glasswing to a controlled set of enterprise partners, including major U.S. financial institutions currently using it for vulnerability detection; the unauthorized access demonstrates that the supply-chain security of frontier AI tools now directly affects the same organizations the tools are designed to protect. The breach occurred not through Anthropic's core infrastructure, but via a third-party vendor environment where a forum member with legitimate contractor credentials — combined with URL pattern knowledge obtained via a prior Mercor Inc. data breach — located and accessed the model without conducting a technical bypass of security controls. While initial reports suggest the cyber threat actor used the model for non-malicious coding tasks rather than exploitation, the incident highlights a critical vulnerability in the artificial intelligence (AI) supply chain: the security of frontier models depends entirely on the weakest link in the partner ecosystem. This development is significant for Florida's critical infrastructure and government sectors. If a model like Mythos, capable of autonomously identifying vulnerabilities at a scale and speed that surpasses all but the most skilled human researchers, falls into the hands of advanced persistent threats (APTs), the window for patching will collapse from days to hours.

Ameriprise Financial Data Breach Impacts Over 47,000 Clients via Compromised Credentials Ameriprise Financial reported a significant data breach affecting approximately 47,600 individuals. The incident involved unauthorized access to corporate accounts through the use of compromised employee credentials. While the company stated that internal systems remained secure, sensitive client information was exfiltrated during the intrusion. This event highlights the persistent threat of credential-stuffing and phishing campaigns targeting the financial sector. Organizations are urged to enforce phishing-resistant multi-factor authentication (MFA) across all administrative and client-facing portals.

Financial Services Sector Recommendations:

- Enforce phishing-resistant MFA across all administrative and client-facing portals to mitigate the persistent threat of credential-stuffing and phishing campaigns.
- Implement real-time monitoring of external data flows and conduct rigorous vendor and third-party risk assessments to secure sensitive PII against supply-chain compromises.
- Educate mobile payment users and retirees on the risks of social engineering and application sideloading to prevent NFC fraud from trojanized applications like NGate.
- Disable NFC functionality on mobile devices when not in use and restrict application installations to verified, official stores.
- Secure AI supply chains by auditing the access controls of third-party partners and contractors who have access to high-capability frontier models.

Food and Agriculture Sector

CISA ICS Advisories for the Food and Agriculture Sector As of April 2026, recent Cybersecurity and Infrastructure Security Agency (CISA) Industrial Control Systems (ICS) advisories, including ICSA-26-092-02 and ICSA-26-029-03, highlighted critical vulnerabilities in automation hardware from vendors like Yokogawa and Rockwell Automation, which are foundational to the Food and Agriculture sector. Key issues include hardcoded credentials in authentication modules (CVE-2025-7741) and vulnerabilities in redundancy modules for high-availability controllers. These flaws could allow unauthorized cyber threat actors to bypass local security, manipulate production parameters, or trigger emergency shutdowns. Such exploits are particularly dangerous in food processing, where precise control over temperatures and chemical concentrations is required to prevent contamination or batch spoilage.

Food and Agriculture Sector Recommendations:

- Disable or change all default and hardcoded credentials in authentication modules, specifically targeting known vulnerabilities in Yokogawa and Rockwell Automation hardware.
- Isolate redundancy modules and high-availability controllers from external networks to prevent unauthorized remote manipulation of production parameters or emergency shutdowns.
- Implement strict network segmentation between automation hardware and administrative systems to safeguard food processing environments that require precise temperature and chemical control.
- Regularly audit industrial control system configurations for unauthorized changes to sensor thresholds or safety parameters that could lead to batch spoilage or contamination.
- Verify that all critical automation controllers are set to "Run" mode or utilize physical hardware-write protection to mitigate the risk of remote configuration tampering.

Government Services and Facilities Sector

U.S. Federal Agency's Cisco Firewall Infected With 'Firestarter' Backdoor A United States federal civilian agency was compromised through a sophisticated backdoor named "FIRESTARTER" that persisted on Cisco Firepower devices running Adaptive Security Appliance (ASA) software. The malware allows for remote control and is not removed by standard firmware updates or soft reboots. It is attributed by Cisco Talos to the espionage-focused threat actor UAT-4356 — the same group behind the 2024 ArcaneDoor campaign — which independent researchers have associated with Chinese networks, though no official nation-state attribution has been made. Attackers exploited CVE-2025-20333 and CVE-2025-20362 before patches were available, deploying the 'LINE VIPER' toolkit and then installing FIRESTARTER prior to September 25, 2025; when the agency subsequently applied Cisco's patches, FIRESTARTER persisted, demonstrating that patching alone did not evict the attacker.. CISA's updated Emergency Directive (V1: ED 25-03) required agencies to submit core dump forensic analysis via the Malware Next Gen portal by April 24, 2026, and to report a full device inventory by May 1, 2026.

Florida Ransomware Negotiator Pleads Guilty to Conspiracy to Deploy Ransomware In a notable insider threat case, a Florida resident working as a professional ransomware negotiator pleaded guilty to participating in a conspiracy to deploy ransomware. The individual utilized his position to facilitate payments and coordinate with cyber threat actors, essentially acting as a bridge for criminal operations. This case underscores the risk of "double-agent" behavior in the incident response industry. Government agencies and critical infrastructure firms should strictly vet third-party cybersecurity partners and implement robust oversight for all negotiation and remediation workflows.

Government Services and Facilities Sector Recommendations:

- Perform a physical hard power cycle (complete power disconnection) on all Cisco Firepower and ASA devices to purge persistent "FIRESTARTER" malware implants. Operator should note, however that a hard power cycle removes the FIRESTARTER persistence mechanism from memory but does not constitute full remediation; Cisco strongly recommends reimaging and upgrading affected devices to a fixed software release to prevent re-compromise.
- Upload device core dumps to the CISA Malware Next Gen portal for forensic analysis and verification of compromise.
- Audit perimeter hardware for unauthorized administrative accounts and manipulate Service Platform mount lists to identify indicators of persistent espionage nodes.
- Vet all third-party cybersecurity partners and ransomware negotiators through rigorous background checks to mitigate the risk of "double-agent" insider threats.

- Implement robust oversight and formal approval workflows for all incident negotiation and remediation activities involving external contractors.

Healthcare and Public Health Sector

Hospital Patient Data May Have Leaked In ChipSoft Hack As of mid-April 2026, Dutch healthcare Information Technology (IT) vendor ChipSoft suffered a ransomware attack that disrupted its flagship HiX Electronic Health Record (EHR) platform. The incident forced eleven hospitals to disconnect patient portals and disabled connections to mobile and healthcare exchange services. While some institutions reported that data remained secure in isolated environments, ChipSoft has not ruled out unauthorized access to sensitive patient records, including national identification numbers and medical histories. This event is relevant to Florida because it underscores the critical sector dependency on third-party EHR vendors; a similar compromise of a major United States healthcare software provider would mirror these operational disruptions and data risks within Florida medical networks.

Massachusetts Hospital Diverts Ambulances As Cyberattack Causes Disruption As of mid-April 2026, Signature Healthcare, based in Brockton, Massachusetts, experienced a ransomware attack attributed to the Anubis cyber threat actor. The intrusion forced the 216-bed hospital to activate downtime procedures, transitioning to manual paper records after its Electronic Health Record (EHR) and patient portal systems were taken offline. Operational impacts included ambulance diversions, the cancellation of chemotherapy treatments, and the closure of retail pharmacies. Cyber threat actors reportedly exfiltrated two terabytes of data, including sensitive patient information. This incident is relevant to Florida critical infrastructure as it highlights the immediate life-safety risks and sector-wide operational strain caused by ransomware-induced downtime in regional medical centers and their supply chains.

Blackwater Ransomware Claims 577GB Stolen From Idaho Hospital As of April 2026, Minidoka Memorial Hospital in Rupert, Idaho, experienced a cyber incident on Easter morning (April 5) that forced the facility to divert emergency patients and limit medical imaging services for nearly two weeks. A newly emerged ransomware collective calling itself "Blackwater" claimed responsibility, alleging the exfiltration of 577 gigabytes (GB) of data—approximately 2.3 million files—and set a ransom deadline for April 24. While the hospital restored imaging access by April 19, the cyber threat actor's entry into the threat landscape mirrors the industrialized double extortion tactics seen in more established ransomware-as-a-service (RaaS) operations. This event is relevant to Florida as it underscores the persistent vulnerability of specialized municipal healthcare facilities. Such disruptions to diagnostic imaging and emergency intake can create critical care gaps in regional trauma networks, necessitating robust offline downtime procedures and segmented network backups for Florida's public health systems.

Maine Advances Bill Requiring Hospitals To Adopt Cybersecurity Plans As of April 23, 2026, the Maine House of Representatives voted unanimously to advance LD 2103, a bill requiring hospitals to implement cybersecurity plans aligned with federal National Institute of Standards and Technology (NIST) and CISA standards. Triggered by 2025 ransomware attacks that affected one-third of the state's residents, the legislation mandates annual employee training, documented incident response plans, and written mutual aid agreements with other hospitals to facilitate patient transfers during system outages. Critically, the bill requires hospitals to maintain backup communication protocols and procedures for incorporating manual charting into electronic records. This development is relevant to Florida as it provides a legislative blueprint for addressing the operational care gaps often exposed during cyberattacks on municipal health systems, emphasizing that technical recovery must be paired with physical clinical continuity plans to safeguard public health.

Serial-to-IP Converter Flaws Expose Healthcare OT Systems to Remote Hijacking Security researchers have disclosed multiple critical vulnerabilities in widely used Serial-to-IP converters, which bridge legacy medical devices and modern Ethernet networks. These flaws, including CVE-2026-4412, allow unauthenticated attackers to execute remote code on the converter, potentially gaining control over connected medical machinery or monitoring systems. Given the prevalence of these converters in hospital environments to support legacy hardware, healthcare providers should immediately identify these devices and move them to isolated, non-routed network segments.

Ransomware Attack on NHS Providers Causes Widespread Service Disruptions A significant ransomware attack targeting a major provider for the National Health Service (NHS) has resulted in widespread operational disruptions, including the cancellation of surgeries and the diversion of emergency patients. While the attack is international, it represents a critical tactical analog for Florida hospitals, as the cyber threat actors successfully targeted a centralized diagnostic service provider to maximize impact across multiple facilities. Healthcare providers are urged to map dependencies on third-party digital pathology and imaging services to ensure continuity during a primary provider outage.

Healthcare and Public Health Sector Recommendations:

- Isolate all Serial-to-IP converters on dedicated, non-routed network segments to protect legacy medical devices from unauthorized remote hijacking.
- Develop and regularly test clinical downtime procedures, including manual paper charting and analog communication protocols, to maintain life-safety services during EHR or portal outages.
- Map all critical dependencies on third-party diagnostic, pathology, and imaging service providers to ensure operational continuity if a centralized vendor is compromised.

- Establish formal "mutual aid" agreements with regional trauma networks to facilitate coordinated emergency patient diversions and data sharing during a sustained cyber incident.
- Implement immutable, segmented network backups specifically for diagnostic imaging and patient record systems to reduce the window of service unavailability following a ransomware attack.

Information Technology Sector

Vulnerability In Intel Utility Allows Threat Actors To Hijack Application Domains As of April 2026, security researchers identified a critical flaw in the Intel Driver and Support Assistant (DSA) that permits AppDomain hijacking. This technique exploits the way .NET applications load configuration files, allowing an attacker with local access to place a malicious file that the utility then executes with elevated privileges. By leveraging this "living-off-the-land" tactics, techniques, and procedures (TTPs), adversaries can bypass security software and establish persistent access without triggering traditional malware alerts. This development is relevant to Florida critical infrastructure because Intel hardware and associated support utilities are ubiquitous across municipal and state agency workstations. Failure to patch this vulnerability could allow an initial local foothold to escalate into a full network compromise of sensitive administrative or operational systems.

CISA Adds Exploited Apache ActiveMQ Vulnerability To KEV Catalog As of April 16, 2026, the Cybersecurity and Infrastructure Security Agency (CISA) and Germany's CERT-Bund issued multiple advisories regarding active exploitation of Apache ActiveMQ. The most critical flaw, CVE-2026-34197, involves improper input validation in the Jolokia Java Management Extensions (JMX) over Hypertext Transfer Protocol (HTTP) bridge. Attackers can exploit this to load a remote malicious Spring XML configuration, leading to arbitrary code execution (RCE) on the Java Virtual Machine (JVM). Additionally, CVE-2026-39304 was identified as a Denial of Service (DoS) vulnerability that exhausts memory through uncontrolled Transport Layer Security (TLS) version 1.3 KeyUpdate requests. These vulnerabilities allow cyber threat actors to disrupt data pipelines or establish an initial foothold for lateral movement. This news is relevant to Florida as ActiveMQ is a foundational component in the data-sharing architectures of many Florida state agencies and municipal utilities. Organizations are mandated or strongly urged to patch to versions 5.19.4 or 6.2.3 by April 30, 2026, to prevent system compromise.

Supply Chain Compromise Impacts Axios Node Package Manager As of April 20, 2026, CISA issued an alert regarding a software supply chain compromise affecting the Axios Node Package Manager (npm) package (versions 1.14.1 and 0.30.4). Cyber threat actors successfully injected a malicious dependency, plain-crypto-js@4.2.1, which was programmed to download additional payloads, including a remote access trojan (RAT), upon installation or update. This attack targets the automated build and deployment pipelines used by developers, allowing the

malware to propagate downstream into enterprise applications without direct interaction from end-users.

UNC6692 Impersonates IT Help Desk via Microsoft Teams to Deploy SNOW Malware As of April 23, 2026, Google Threat Intelligence (Mandiant) identified a new threat cluster, UNC6692, using a high-pressure "double-tap" tactic. The attack begins by flooding a user's inbox with thousands of spam emails to create a sense of crisis. The cyber threat actor then reaches out via Microsoft Teams from an external account, posing as corporate information technology (IT) support offering to resolve the issue. Victims are directed to a fake "Mailbox Repair" site that harvests credentials, using a double-entry trick to ensure accuracy, and silently installs the SNOW malware suite via AutoHotKey scripts.

Unauthenticated RCE in Breeze Cache WordPress Plugin Exploited in the Wild A critical file-upload vulnerability (CVE-2026-3844) in the Breeze Cache WordPress plugin, active on over 400,000 sites, is being actively exploited. The flaw exists in the 'fetch_gravatar_from_remote' function and allows unauthenticated attackers to upload arbitrary files to the server, leading to full RCE. The vulnerability is exploitable if the "Host Files Locally - Gravatars" feature is enabled. Administrators must update to version 2.4.5 immediately or disable the gravatar hosting feature to mitigate the risk of server takeover.

Over 1,300 Microsoft SharePoint Servers Compromised via Actively Exploited Flaw Cyber threat actors are actively exploiting a critical vulnerability in Microsoft SharePoint (CVE-2026-24906) to bypass authentication and execute remote code. Since mid-April, over 1,300 servers have been confirmed as compromised globally, with attackers utilizing the access to deploy ransomware and harvest internal documents. Given the widespread use of SharePoint for internal document management across Florida's public and private sectors, administrators should verify patch levels and monitor for unauthorized administrative account creation.

Popular Thymeleaf Java Template Engine Patches Critical Sandbox Bypass A critical sandbox bypass vulnerability (CVE-2026-3112) has been fixed in the Thymeleaf Java template engine, a tool used in thousands of web applications. The flaw allows an attacker to execute arbitrary code by bypassing the engine's restricted expression execution environment. If a web application allows user input to be processed by the template engine, it is vulnerable to full server takeover. Developers are urged to update to version 3.1.4 immediately to mitigate the risk of RCE.

N-Gate Android Malware Uses NFC Relays to Steal Credit Card Data Globally A new Android malware family, NGate, is utilizing Near Field Communication (NFC) relay technology to steal payment card data. The malware captures data from a physical card and relays it to an attacker's device, which can then be used to perform unauthorized contactless payments or automated teller machine (ATM) withdrawals. This represents an evolution in mobile financial malware, moving beyond simple credential theft to physical asset manipulation. Users are

advised to disable NFC when not in use and avoid installing applications from unverified third-party sources.

Vercel Breach Tied to Compromised Context AI Infrastructure Cloud platform provider Vercel confirmed a security breach resulting from a compromise of Context AI, a third-party analytics provider used by Vercel. Attackers gained access to internal tokens and configuration data, highlighting a growing trend of "nested" supply-chain attacks where cyber threat actors target smaller, specialized artificial intelligence (AI)/analytics firms to reach large-scale platform providers. Organizations utilizing Vercel or similar continuous integration and continuous delivery (CI/CD) platforms should immediately rotate environment variables and audit access logs for unauthorized "Vercel-Bot" activity.

Critical Flaw in Protobuf Library Enables Remote JavaScript Code Execution A critical vulnerability (CVE-2026-3812) has been disclosed in the Google Protocol Buffers (Protobuf) JavaScript library. The flaw allows an attacker to achieve RCE by sending specially crafted malicious payloads that bypass prototype pollution protections. Given the ubiquity of Protobuf in modern web applications and microservices for data serialization, this represents a significant risk to IT infrastructure providers. Developers are urged to update to the latest patched version of the protobuf-js library immediately.

Microsoft-Signed Malware Observed Evading Endpoint Detection in Financial Sector Targets Security researchers have identified a new campaign where cyber threat actors are utilizing malicious drivers that have been legitimately signed through the Microsoft Windows Hardware Developer Program. By abusing the trust associated with Microsoft signatures, the malware, often a variant of the AuraBoros toolkit, is able to disable endpoint detection and response (EDR) and antivirus solutions before deploying final-stage ransomware. This technique has been observed in recent intrusions targeting U.S. financial services. Administrators should implement strict driver-signing policies and utilize Windows Defender Application Control (WDAC) to block unauthorized kernel-mode drivers.

"Comment and Control" Prompt Injection Bypasses Guardrails in Gemini CLI and Claude Code Researchers have disclosed a novel prompt injection attack method named "Comment and Control" that successfully targets several popular AI coding and automation tools, including Google's Gemini CLI and Anthropic's Claude Code. The attack leverages specially crafted GitHub comments, issue bodies, or Pull Request (PR) titles to bypass environment filtering and exfiltrate production secrets or Application Programming Interface (API) keys. This is particularly dangerous for AI agents given powerful tools like bash execution or git push. While vendors have implemented preliminary guardrails, the underlying architectural flaw, processing untrusted user input in the same runtime as production secrets, remains a critical risk for developer operations (DevOps) teams utilizing AI-assisted automation.

Critical LiteLLM Flaw Enables Database Attacks and Credential Theft A critical vulnerability in the LiteLLM Python library was exploited to insert malicious code that harvested credentials from thousands of companies. The breach specifically targeted the software supply chain by compromising the Trivy security scanning tool first. Stolen data are exfiltrated to malicious servers. Florida organizations using LiteLLM for AI application development should rotate all potentially impacted passwords and audit their developer environments for signs of the supply chain threat.

Incomplete Windows Patch Opens Door to Zero-Click Attacks Security researchers have identified that an incomplete Microsoft patch for a Windows MSHTML vulnerability allows for continued zero-click RCE attacks. Attackers are bypassing original mitigations by using specially crafted files to trigger the vulnerability without user interaction. This flaw is particularly dangerous as it can be delivered via email or web-based vectors. Florida IT administrators are urged to apply the latest cumulative updates and monitor for unusual MSHTML process activity to mitigate the risk of server takeover.

Information Technology Sector Recommendations:

- Patch Microsoft SharePoint servers immediately to remediate CVE-2026-24906 and monitor for unauthorized administrative account creation.
- Update the Breeze Cache WordPress plugin to version 2.4.5 or disable the "Host Files Locally - Gravatars" feature to prevent unauthenticated RCE.
- Implement strict driver-signing policies and utilize WDAC to block unauthorized, legitimately signed malicious kernel-mode drivers.
- Verify and update Apache ActiveMQ to versions 5.19.4 or 6.2.3 by April 30, 2026, to mitigate Jolokia-based code execution and DoS vulnerabilities.
- Audit DevOps environments for the "Comment and Control" prompt injection flaw by ensuring untrusted user input is not processed in the same runtime as production secrets or API keys.

Nuclear Reactors, Materials, and Waste Sector

No sector-specific incidents, advisories, or tactically relevant reporting were identified during this biweekly reporting period.

Transportation Systems Sector

TSA Seeks Input on Cybersecurity Reporting and Assessment Burden for Pipeline and Rail Operators The Transportation Security Administration (TSA) has opened a comment period, closing June 15, 2026, regarding the burden and effectiveness of current cybersecurity reporting requirements for pipeline and rail operators. This initiative aims to refine how critical

infrastructure (CI) entities report incidents and manage vulnerability assessments. Transportation stakeholders in Florida are encouraged to participate in this process to ensure that reporting mandates remain operationally feasible while maintaining national security standards.

Transportation Systems Sector Recommendations:

- Participate in the TSA public comment period by June 15, 2026, to provide feedback on the operational feasibility and effectiveness of current cybersecurity reporting mandates.
- Evaluate internal incident response and vulnerability assessment workflows to identify specific administrative burdens for inclusion in stakeholder feedback to the TSA.
- Coordinate with regional transportation partners to ensure that reporting standards maintain national security while reflecting the specific infrastructure needs of Florida's pipeline and rail networks.
- Review existing pipeline and rail security directives to ensure current compliance with TSA reporting requirements while refinements are being considered.
- Implement automated logging and reporting tools where possible to streamline the collection of incident data required by federal mandates.

Water and Wastewater Systems Sector

Ransomware Attack Hits Romanian Waters Authority Compromising Administrative Systems

As of late April 2026, the Romanian National Administration "Romanian Waters" (ANAR) suffered a ransomware attack that compromised internal servers and encrypted administrative data. While the agency reported that the technical systems controlling dams and flood monitoring remained operational due to network segmentation, the loss of administrative connectivity hindered internal communications and reporting. This attack highlights the persistent targeting of water management authorities by cybercriminals seeking high-leverage victims. This development is relevant to Florida as it serves as a critical reminder of the necessity of robust network air-gapping between business networks and operational technology (OT); a similar breach in Florida could disrupt the administrative workflows essential for coordinated flood control and environmental monitoring during active weather events.

Censys Brief Highlights High Exposure of FTP Servers Supporting Water Management Systems

A global scan by Censys has identified a significant number of publicly accessible file transfer protocol (FTP) servers integrated into water and wastewater management systems. These servers, often used for log collection and firmware updates, are frequently configured with weak or default credentials, exposing critical system configurations and operational data to the public internet. This exposure is a primary initial access vector for hacktivist groups. Water utilities in Florida should perform immediate scans for internet-exposed FTP services and enforce strict firewall rules to limit access to authorized internet protocol (IP) ranges only.

Water and Wastewater Systems Sector Recommendations:

- Perform immediate scans for internet-exposed FTP services and enforce strict firewall rules to restrict access to authorized IP ranges only.
- Disable or replace all default and weak credentials on FTP servers and OT hardware used for log collection and firmware updates.
- Implement robust network air-gapping and hardware-enforced segmentation between administrative business networks and technical systems controlling dams or flood monitoring.
- Ensure all municipal water and wastewater controllers are set to "Run" mode or utilize physical write-protection switches to prevent unauthorized remote configuration changes.
- Develop and maintain manual fallback procedures for coordinated flood control and environmental monitoring to ensure operational continuity during an administrative network outage.

Cyber Threat Actor (CTA) Summary — Critical Infrastructure Focus

Iran-based CTAs

- Primary intent is disruption of U.S. critical infrastructure. Current operations are opportunistic, exploiting basic security gaps, but actors are actively refining toward more destructive, physical effects.
- Iranian-linked actors are conducting psychological operations and direct harassment of U.S. military personnel — including personalized threats of kinetic strikes via encrypted messaging — signaling an intent to extend pressure beyond cyber effects.
- Pro-Iranian proxies amplify low-level intrusions through information operations to exaggerate impact, and conduct high-volume denial-of-service attacks against U.S. IT and communications infrastructure.

China-based CTAs

- Strategic focus is long-term espionage against U.S. government, defense, and aerospace targets, with expanding reach into healthcare, transportation, and government CI nodes.
- Actors are systematically building deniable proxy networks through compromised consumer routers and IoT devices, and actively mapping supply chain vulnerabilities to reach defense sector targets indirectly. Treat third-party and vendor access as an elevated risk surface.

Russia-based CTAs

- APT28 is conducting sustained credential harvesting and email compromise against government and legal entities. Current targeting centers on Eastern Europe, but TTPs transfer directly to U.S. Government Facilities and Defense Industrial Base sectors.
- Assess this as a pre-positioning threat: access is being established now; disruptive effects may follow.

North Korea-based CTAs

- State-backed actors are targeting Healthcare and Public Health — specifically pharmaceutical and life science firms — for data theft, and are demonstrating advanced financial sector exploitation capability, generating hundreds of millions in illicit revenue to fund state objectives.
- A separate cluster infiltrates organizations through fraudulent remote hiring, abusing legitimate insider access to steal data and enable follow-on compromise. CI operators with contractor-heavy or remote-hire pipelines face elevated exposure.

Unattributed / Other CTAs

- Financially motivated ransomware groups pose a sustained, high-volume threat to smaller CI operators and municipal networks. Actors continue shifting toward targeted, high-impact operations. Active intra-adversary conflict between ransomware syndicates (including infrastructure leaks and personnel exposure) is temporarily degrading some groups' operational readiness, but should not be interpreted as a reduced threat posture overall.
- Supply chain and cloud environments remain high-priority targets. Actors such as ShinyHunters are compromising third-party business tools to harvest authentication tokens and pivot into connected enterprise cloud platforms for mass data exfiltration and extortion. Vendor access and federated authentication represent standing control gaps.
- Social engineering and hacking collectives such as Scattered Spider are recruiting technically skilled youth to achieve network penetration through impersonation, identity fraud, and aggressive wire fraud schemes. Identity verification for internal support requests and new hire onboarding should be treated as active risk surfaces.
- Emerging ransomware variants deploying post-quantum encryption against virtualized infrastructure represent a forward-looking capability gap: standard recovery options will not apply if this capability scales.